CONTROL DE CAMBIOS.

Versión	Fecha		Descripción	Responsable
1.0	2025-03-27		Primera versión.	Francisco Oliveros

Elaborado por:	Revisado por:	Aprobado por:
Francisco Oliveros	Alejandro Álvarez	Santiago Montoya

Contenido

1. Introducción 4
1.1 Propósito 4
1.2 Alcance 4
1.3 Principios de Seguridad de la Información 4
1.4 Relación con el Marco Regulatorio 4
1.5 Compromiso de la Alta Dirección 4
2. Alcance 5
2.1 Aplicabilidad 5
2.2 Ámbitos de Protección 5
2.3 Exclusiones y Limitaciones 5
2.4 Relación con Otras Políticas 5
2.5 Cumplimiento y Responsabilidades 6
3. Principios de Seguridad 6
3.1 Confidencialidad 6
3.2 Integridad 6
3.3 Disponibilidad 7
3.4 Autenticidad 7
3.5 Trazabilidad 7
3.6 Cumplimiento Normativo 7
3.7 Cultura de Seguridad 8
4. Procedimientos de Seguridad 8
4.2 Procedimiento de Protección de Datos 9
4.3 Procedimiento de Gestión de Incidentes de Seguridad 9
4.4 Procedimiento de Seguridad en el Desarrollo de Software 9
4.5 Procedimiento de Gestión de Proveedores y Terceros 10
4.6. Procedimiento de Seguridad en el Uso de Dispositivos 10
4.7 Procedimiento de Concientización y Capacitación 10
5.2 Evaluación y Análisis de Riesgos 11
5.3 Medidas de Control y Mitigación de Riesgos 12
5.3.1 Medidas Preventivas (Evitar que ocurra el riesgo) 12
5.3.2 Medidas Detectivas (Identificar riesgos en tiempo real) 12
5.3.3 Medidas Correctivas (Responder y minimizar el impacto de un riesgo) 13
5.4 Plan de Acción ante Riesgos Críticos 13
5.5 Monitoreo y Mejora Continua 13
6. Cumplimiento y Actualización 13
6.1 Cumplimiento de la Política de Seguridad 13
6.1.1 Responsabilidades del Cumplimiento 14
6.1.2 Auditorías y Evaluaciones de Cumplimiento 14

6.1.3 Consecuencias del Incumplimiento 14
6.2 Actualización de la Política de Seguridad 14
6.2.1 Frecuencia de Actualización 14
6.2.2 Proceso de Actualización 15
6.2.3 Comunicación de Actualizaciones 15
6.3 Integración con Normativas y Estándares 15

1. Introducción

1.1 Propósito

La seguridad de la información es un pilar fundamental para **Auco**, dado que manejamos datos sensibles relacionados con la firma electrónica, la identidad digital y la verificación de antecedentes en múltiples países. Esta **Política de Seguridad de la Información (PSI)** tiene como objetivo establecer un marco para la **protección, integridad, confidencialidad y disponibilidad** de la información dentro de la organización.

Nuestra infraestructura tecnológica, los procesos de negocio y la interacción con clientes y aliados estratégicos dependen de una gestión efectiva de la seguridad de la información. Por ello, esta política se alinea con **ISO 27001** y otras normativas aplicables, garantizando el cumplimiento de estándares internacionales y locales.

1.2 Alcance

Esta política aplica a: **Todos los empleados, contratistas y terceros** con acceso a los sistemas y datos de Auco.
Toda la información generada, procesada, almacenada y transmitida en la empresa, en **soporte digital**.
Infraestructura tecnológica utilizada para la gestión de la firma electrónica y la validación de identidad.
Proveedores y aliados estratégicos que interactúan con los datos de Auco.

El cumplimiento de esta política es obligatorio y cualquier incumplimiento será evaluado conforme a los procedimientos internos de gestión de riesgos y sanciones.

1.3 Principios de Seguridad de la Información

Nuestra política se fundamenta en los siguientes principios clave:

Confidencialidad: Garantizar que la información solo sea accesible para quienes tienen autorización.

Integridad: Asegurar la precisión y confiabilidad de los datos, evitando alteraciones no autorizadas.

Disponibilidad: Mantener la información accesible para los usuarios legítimos cuando la necesiten.

Autenticidad: Verificar la identidad de los usuarios y entidades que acceden a la información.

Trazabilidad: Registrar y monitorear todas las acciones realizadas sobre los sistemas de información.

1.4 Relación con el Marco Regulatorio

Auco opera bajo un entorno regulado por normativas internacionales y locales, incluyendo: **ISO 27001:** Estándar internacional para la gestión de la seguridad de la información. **Regulación de Firma Electrónica en Colombia (Ley 527 de 1999 y Decreto 2364 de 2012). Reglamentos de protección de datos personales (Ley 1581 de 2012 y GDPR, si aplica)..**

El cumplimiento de estas regulaciones es prioritario para la continuidad y confianza en nuestros servicios.

1.5 Compromiso de la Alta Dirección

La alta dirección de Auco respalda esta política, promoviendo una cultura de seguridad y asignando los recursos necesarios para su implementación y mejora continua. Todos los empleados y colaboradores son responsables de seguir los lineamientos aquí establecidos.

2. Alcance

2.1 Aplicabilidad

La **Política de Seguridad de la Información (PSI)** de **Auco** se aplica a **todas las áreas, procesos, empleados y sistemas tecnológicos** de la empresa, con el fin de garantizar la protección de la información en todas sus formas y medios.

Esta política es de cumplimiento obligatorio para:

Todos los empleados y colaboradores (permanentes, temporales y subcontratados).

Terceros, proveedores y aliados estratégicos que manejen, procesen o almacenen información de Auco.

Clientes y usuarios finales, en lo que respecta al uso de los sistemas y plataformas de la empresa.

Toda la información procesada, transmitida, almacenada o eliminada en el contexto de los servicios de firma electrónica, verificación de identidad y gestión documental.

2.2 Ámbitos de Protección

La política cubre la seguridad de la información en los siguientes aspectos clave:

Infraestructura tecnológica: Aplicaciones, bases de datos, servidores, redes y dispositivos utilizados en la prestación de los servicios de Auco.

Plataformas digitales y canales de comunicación: Incluyendo la plataforma de firma electrónica, integración con WhatsApp, APIs con aliados estratégicos y otros medios de intercambio de información.

Documentos y registros físicos y digitales: Que contengan información confidencial de clientes, empleados o proveedores.

Procesos de negocio: Relacionados con la autenticación de identidad, validación de antecedentes, automatización documental y firma electrónica.

Acceso a la información: Controlando quién, cómo y cuándo se accede a los sistemas y datos de la organización.

Gestión de incidentes de seguridad: Incluyendo la detección, respuesta y mitigación de riesgos relacionados con ciberseguridad y protección de datos.

2.3 Exclusiones y Limitaciones

Si bien esta política tiene un **enfoque integral**, se establecen algunas exclusiones:

Información pública: Que no requiera medidas específicas de seguridad según su clasificación.

Equipos o redes personales: A menos que se usen para acceder a sistemas de la empresa (en cuyo caso deben cumplir las políticas de seguridad definidas).

Información de terceros ajenos a la empresa: Que no sea procesada ni almacenada en los sistemas de Auco.

2.4 Relación con Otras Políticas

Esta política se complementa con otros lineamientos internos, como:

Política de Control de Acceso: Define cómo se gestionan los permisos y credenciales de los usuarios.

Política de Gestión de Incidentes: Establece el procedimiento para identificar y responder ante incidentes de seguridad.

Política de Continuidad del Negocio: Asegura que la empresa pueda seguir operando en caso de eventos disruptivos.

Política de Protección de Datos Personales: Regula el tratamiento de información sensible y el cumplimiento normativo.

2.5 Cumplimiento y Responsabilidades

Todos los empleados, proveedores y terceros deben cumplir esta política. Su desconocimiento **no exime de responsabilidad** en caso de incumplimientos o incidentes de seguridad.

La alta dirección de **Auco** garantiza el cumplimiento de esta política mediante auditorías, revisiones periódicas y programas de concienciación.

3. Principios de Seguridad

Los principios de seguridad de la información establecen los lineamientos fundamentales para garantizar la **protección, integridad y disponibilidad** de la información dentro de **Auco**. Estos principios están alineados con **ISO 27001** y otras normativas internacionales, asegurando un enfoque robusto y sistemático en la gestión de la seguridad.

3.1 Confidencialidad

La confidencialidad garantiza que la información solo sea accesible por personas, sistemas o procesos autorizados. **Auco** protege la información sensible mediante:

Control de acceso basado en roles (RBAC): Solo los usuarios con los permisos adecuados pueden acceder a información crítica.

Autenticación fuerte: Uso de autenticación multifactor (MFA) para minimizar riesgos de accesos no autorizados.

Cifrado de datos: Protección de información almacenada y en tránsito mediante algoritmos de cifrado avanzados.

Acuerdos de confidencialidad (NDA): Firmados con empleados, proveedores y terceros que manejan información crítica.

Ejemplo práctico: Solo el personal autorizado puede acceder a bases de datos que contienen información de clientes y procesos de firma electrónica.

3.2 Integridad

La integridad garantiza que la información se mantenga **completa, precisa y sin alteraciones no autorizadas**. Para ello, Auco implementa:

Controles de auditoría y trazabilidad: Registro detallado de accesos, modificaciones y transacciones en los sistemas.

Mecanismos de hash y firma digital: Aseguran la autenticidad de documentos y transacciones electrónicas.

Restricción de privilegios: Limitación de permisos de edición o modificación a usuarios específicos según sus funciones.

Verificación y validación de datos: Uso de inteligencia artificial para detectar fraudes y documentos falsos.

Ejemplo práctico: Si un documento firmado digitalmente es alterado después de su firma, el sistema lo detecta y lo invalida automáticamente.

3.3 Disponibilidad

La disponibilidad garantiza que la información y los sistemas estén accesibles cuando sean requeridos por usuarios autorizados. Para ello, Auco implementa:

Alta disponibilidad en infraestructura: Servidores redundantes y balanceo de carga para minimizar interrupciones.

Monitoreo 24/7: Detección proactiva de fallas, ataques o incidentes de seguridad.

Planes de continuidad del negocio y recuperación ante desastres: Protocolos para garantizar la operación en caso de incidentes críticos.

Actualizaciones y mantenimiento preventivo: Aplicación de parches de seguridad y optimización de sistemas para evitar vulnerabilidades.

Ejemplo práctico: En caso de caída de un servidor, el sistema redirige automáticamente las operaciones a un servidor de respaldo sin afectar la experiencia del usuario.

3.4 Autenticidad

La autenticidad asegura que la identidad de los usuarios, sistemas y procesos sea legítima, evitando suplantaciones. **Auco** garantiza este principio mediante:

Autenticación multifactor (MFA): Combinación de credenciales como contraseñas, tokens y biometría.

Certificados digitales y firma electrónica: Validación segura de la identidad de usuarios y transacciones.

Verificación de identidad en tiempo real: Mediante IA y análisis de documentos en más de 49 países.

Control de accesos físicos y digitales: Uso de credenciales y monitoreo para evitar intrusiones.

Ejemplo práctico: Un usuario que accede a la plataforma de firma electrónica debe validar su identidad con un código enviado a su correo o dispositivo móvil.

3.5 Trazabilidad

La trazabilidad permite el seguimiento de todas las acciones realizadas sobre la información y los sistemas. **Auco** implementa:

Registros de actividad (logs): Captura y almacenamiento de todas las interacciones dentro de los sistemas.

Auditorías periódicas: Evaluaciones de cumplimiento y detección de anomalías en el uso de la información.

Alertas y monitoreo en tiempo real: Identificación de comportamientos sospechosos o intentos de acceso no autorizados.

Políticas de retención y eliminación de datos: Definición de tiempos de conservación de información según regulaciones.

Ejemplo práctico: Si un usuario intenta acceder a información restringida, el intento es registrado y se genera una alerta automática para el equipo de seguridad.

3.6 Cumplimiento Normativo

El cumplimiento de regulaciones y normativas es clave en la seguridad de la información. **Auco** sigue estándares como:

ISO 27001: Gestión de la seguridad de la información.

Regulación de Firma Electrónica en Colombia (Ley 527 de 1999 y Decreto 2364 de 2012).

Protección de datos personales (Ley 1581 de 2012 y GDPR, si aplica).

Normativas específicas de aliados estratégicos

Ejemplo práctico: Todos los procedimientos de seguridad deben cumplir con las regulaciones vigentes y estar sujetos a auditorías.

3.7 Cultura de Seguridad

La seguridad de la información no es solo un aspecto técnico, sino también cultural. **Auco** fomenta la seguridad a través de:

Capacitaciones periódicas: Formación a empleados sobre buenas prácticas de seguridad y prevención de ataques.

Políticas claras y accesibles: Disponibilidad de normativas de seguridad para todos los colaboradores.

Concienciación sobre riesgos: Simulación de ataques de phishing y pruebas de respuesta ante incidentes.

Responsabilidad compartida: Todos los empleados tienen el deber de reportar incidentes o anomalías.

Ejemplo práctico: Un empleado recibe una capacitación sobre cómo identificar correos electrónicos fraudulentos para evitar ataques de phishing.

4. Procedimientos de Seguridad

Los **procedimientos de seguridad** establecen las acciones concretas para implementar los principios de seguridad definidos en la **Política de Seguridad de la Información (PSI)** de **Auco**. Estos procedimientos aseguran que la información se proteja de manera efectiva en todas las etapas de su ciclo de vida, desde la creación hasta la eliminación.

A continuación, se detallan los principales procedimientos de seguridad aplicados en la organización.

4.1 Procedimiento de Control de Acceso

Este procedimiento regula quién, cómo y cuándo se accede a la información y los sistemas de Auco, garantizando la confidencialidad y minimizando riesgos de accesos no autorizados.

Autenticación Multifactor (MFA): Implementada en sistemas críticos para asegurar que solo usuarios legítimos accedan a la información.

Gestión de Roles y Permisos (RBAC): Se otorgan permisos con base en el rol del usuario, aplicando el principio de **mínimos privilegios**.

Monitoreo de Accesos: Registro y auditoría de todas las sesiones para detectar actividades sospechosas.

Revisión Periódica de Permisos: Se revisan y revocan accesos de empleados que cambian de rol o dejan la organización.

Acceso Seguro a Sistemas Remotos: Implementación de VPN y controles adicionales para conexiones externas.

Ejemplo práctico: Un usuario que intenta acceder al sistema de gestión documental de **Auco** desde un dispositivo no autorizado recibirá una alerta de seguridad y deberá autenticarse mediante MFA.

4.2 Procedimiento de Protección de Datos

Este procedimiento define las medidas para garantizar la integridad y confidencialidad de los datos almacenados, transmitidos o procesados.

Cifrado de Datos Sensibles: Aplicado tanto en reposo (bases de datos) como en tránsito (comunicaciones).

Uso de Firma Digital y Sellado de Tiempo: Para garantizar la autenticidad e integridad de documentos electrónicos.

Clasificación de la Información: Identificación y categorización de datos en función de su criticidad y sensibilidad.

Controles de Exportación de Datos: Restricción de copias y transferencias de datos a dispositivos no autorizados.

Política de Retención y Eliminación de Datos: Eliminación segura de información según normativas de protección de datos (ISO 27001, Ley 1581 de 2012, GDPR).

Ejemplo práctico: Si un empleado intenta descargar información de clientes en un dispositivo personal, el sistema bloqueará la acción y notificará al equipo de seguridad.

4.3 Procedimiento de Gestión de Incidentes de Seguridad

Define los pasos a seguir para detectar, responder y mitigar incidentes de seguridad de la información.

Detección y Reporte: Uso de herramientas de monitoreo para identificar intentos de intrusión, malware o accesos no autorizados.

Clasificación del Incidente: Determinación del nivel de impacto y urgencia del incidente.

Respuesta y Contención: Aplicación de medidas inmediatas para limitar el daño (bloqueo de cuentas comprometidas, aislamiento de redes, etc.).

Investigación y Análisis: Evaluación de la causa raíz para prevenir incidentes similares en el futuro.

Notificación a las Partes Afectadas: Comunicación transparente en caso de incidentes que comprometan datos personales o información crítica.

Documentación y Mejora Continua: Registro de todos los incidentes para optimizar procesos y reforzar controles de seguridad.

Ejemplo práctico: Un intento de acceso no autorizado a una cuenta de administrador genera una alerta automática y el sistema bloquea la cuenta hasta que el usuario verifique su identidad.

4.4 Procedimiento de Seguridad en el Desarrollo de Software

Establece las prácticas para desarrollar software seguro en los sistemas de **Auco**, minimizando vulnerabilidades en aplicaciones de firma electrónica, validación de identidad y automatización de documentos.

Revisión de Código Seguro: Aplicación de análisis estático y dinámico del código fuente para detectar vulnerabilidades.

Pruebas de Penetración: Simulación de ataques para evaluar la resistencia de las aplicaciones.

Control de Versiones y Parches: Aplicación rápida de actualizaciones para corregir fallos de seguridad.

Principio de Seguridad por Diseño: Incorporación de controles de seguridad desde la fase inicial del desarrollo.

Ambientes Segregados: Separación de entornos de desarrollo, prueba y producción para evitar fugas de datos.

Ejemplo práctico: Antes de lanzar una nueva versión de la plataforma de firma electrónica, se realizan pruebas de penetración para identificar posibles vulnerabilidades.

4.5 Procedimiento de Gestión de Proveedores y Terceros

Asegura que los proveedores y aliados estratégicos que manejan información de **Auco** cumplan con los estándares de seguridad requeridos.

Evaluación de Seguridad de Proveedores: Antes de firmar contratos, se verifica que los proveedores cumplan con normativas de seguridad como ISO 27001 o GDPR.

Cláusulas Contractuales de Seguridad: Se incluyen acuerdos de confidencialidad (NDA) y requisitos de protección de datos.

Auditorías Periódicas: Se revisa el cumplimiento de controles de seguridad en proveedores clave.

Monitoreo de Integraciones: Evaluación continua de APIs y sistemas externos que interactúan con la información de Auco.

Ejemplo práctico: Si un proveedor de validación de identidad no cumple con los requisitos de cifrado exigidos, **Auco** exige mejoras antes de continuar con la integración.

4.6. Procedimiento de Seguridad en el Uso de Dispositivos

Define las reglas para el uso seguro de dispositivos dentro de la organización.

Gestión de Dispositivos Corporativos: Todos los dispositivos de la empresa deben cumplir con configuraciones de seguridad específicas.

Política de Bring Your Own Device (BYOD): Definición de controles cuando los empleados usan dispositivos personales para acceder a sistemas de la empresa.

Protección contra Malware: Instalación obligatoria de antivirus y herramientas de detección de amenazas.

Control de Conexiones a Redes Externas: Restricción de acceso a redes Wi-Fi públicas o inseguras.

Cifrado y Bloqueo Remoto: En caso de robo o extravío, los dispositivos pueden ser bloqueados y borrados remotamente.

Ejemplo práctico: Si un empleado usa su celular personal para acceder a la plataforma de **Auco**, deberá activar el cifrado del dispositivo y utilizar una VPN segura.

4.7 Procedimiento de Concientización y Capacitación

Promueve la cultura de seguridad entre los empleados y colaboradores.

Capacitaciones Periódicas: Formación en ciberseguridad, phishing, contraseñas seguras y buenas prácticas.

Simulación de Ataques: Pruebas de phishing para evaluar el nivel de conciencia del personal.

Evaluaciones de Conocimiento: Pruebas regulares para medir la efectividad de las capacitaciones.

Política de Seguridad Visible: Acceso fácil a las políticas de seguridad para consulta de los empleados.

Ejemplo práctico: Un empleado recibe un correo sospechoso simulando un ataque de phishing. Si lo reporta correctamente, recibe reconocimiento como parte del programa de seguridad.

5. Riesgos de Seguridad de la Información - Política de Seguridad de la Información

El **riesgo de seguridad de la información** se define como la posibilidad de que una amenaza explote una vulnerabilidad, causando un impacto negativo en la **confidencialidad, integridad y disponibilidad (CID)** de los datos y sistemas de **Auco**.

Este apartado identifica y clasifica los principales riesgos, sus causas, impactos y medidas de mitigación, asegurando que la empresa pueda prevenir, detectar y responder eficazmente a incidentes de seguridad.

5.1 Clasificación de los Riesgos de Seguridad

Los riesgos de seguridad pueden clasificarse en las siguientes categorías:

Categoría	Descripción	Ejemplo
Riesgos de Acceso No Autorizado	Accesos indebidos a sistemas, datos o infraestructura.	Robo de credenciales de un usuario clave.
Riesgos de Malware y Ataques Cibernéticos	Virus, ransomware, phishing o ataques de denegación de servicio.	Un empleado abre un correo de phishing que instala malware.
Riesgos de Pérdida de Datos	Eliminación, alteración o robo de información crítica.	Un fallo en el almacenamiento provoca la pérdida de datos firmados electrónicamente.
Riesgos de Vulnerabilidades en Sistemas	Brechas en software o configuraciones deficientes que permiten ataques.	Un sistema no actualizado permite una intrusión remota.
Riesgos de Ingeniería Social	Manipulación de empleados para obtener información sensible.	Un atacante se hace pasar por un directivo para solicitar acceso a bases de datos.
Riesgos de Fallas en Infraestructura	Problemas en servidores, redes o hardware que afectan la disponibilidad.	Una caída de servidores deja inactiva la plataforma de firma digital.
Riesgos de Cumplimiento Regulatorio	Incumplimiento de normativas de seguridad y protección de datos.	No aplicar correctamente la Ley 1581 de 2012 (protección de datos personales).

5.2 Evaluación y Análisis de Riesgos

Para gestionar los riesgos, **Auco** aplica una metodología basada en ISO 27005, que incluye:

1. **identificación del riesgo:** Se determinan los activos críticos y las posibles amenazas.

2. **Análisis del impacto:** Se evalúa cómo afectaría el riesgo a la operación, reputación y cumplimiento legal.

3. **Probabilidad de ocurrencia:** Se mide la posibilidad de que el riesgo ocurra.

4. **Nivel de riesgo:** Se calcula considerando impacto y probabilidad (riesgo bajo, medio o alto).

5. **Medidas de mitigación:** Se establecen controles para reducir la probabilidad o impacto del riesgo.

Riesgo	Impacto	Probabilidad	Nivel de Riesgo	Acciones de Mitigación
Phishing	Alto	Alta	**Crítico**	Implementar autenticación multifactor y capacitaciones.
Pérdida de datos	Alto	Media	**Alto**	Copias de seguridad automáticas y cifrado de información.
Ataque de ransomware	Crítico	Media	**Crítico**	Restricción de ejecución de macros y backups protegidos.
Acceso indebido a sistemas	Medio	Alta	**Alto**	Gestión de accesos basada en roles y auditoría de logs.
Falla de servidores	Alto	Baja	**Medio**	Infraestructura redundante y monitoreo 24/7.

5.3 Medidas de Control y Mitigación de Riesgos

Para reducir los riesgos identificados, **Auco** implementa una combinación de medidas preventivas, detectivas y correctivas.

5.3.1 Medidas Preventivas (Evitar que ocurra el riesgo)

Autenticación multifactor (MFA): Para prevenir accesos no autorizados.

Capacitación en ciberseguridad: Simulación de ataques de phishing y concienciación sobre ingeniería social.

Actualización de software y parches de seguridad: Evita la explotación de vulnerabilidades.

Gestión de accesos basada en roles (RBAC): Otorgar permisos mínimos necesarios a cada usuario.

Cifrado de datos sensibles: Protege la información en tránsito y en reposo.

Ejemplo: Si un empleado intenta acceder a un sistema sin autenticación multifactor, se le bloquea el acceso hasta que complete la verificación.

5.3.2 Medidas Detectivas (Identificar riesgos en tiempo real)

Monitoreo de actividad 24/7: Identificación de accesos inusuales o intentos de intrusión.

Sistemas de detección de intrusos (IDS/IPS): Alertas ante posibles ataques.

Análisis de registros (logs): Auditoría de eventos críticos para detectar anomalías.

Escaneo de vulnerabilidades: Evaluaciones continuas para detectar fallos en la infraestructura.

Ejemplo: Un intento de acceso masivo desde una dirección IP sospechosa genera una alerta automática al equipo de seguridad.

5.3.3 Medidas Correctivas (Responder y minimizar el impacto de un riesgo)

Planes de respuesta a incidentes: Definición de acciones para contener y resolver incidentes.

Copias de seguridad diarias: Recuperación rápida en caso de pérdida de datos o ransomware.

Restauración de sistemas: Protocolos para minimizar el tiempo de inactividad tras una falla.

Notificación a usuarios y autoridades: En caso de incidentes que afecten información personal o regulada.

Ejemplo: Si un ataque de ransomware cifra información crítica, el equipo de TI activa el protocolo de recuperación desde copias de seguridad.

5.4 Plan de Acción ante Riesgos Críticos

Para riesgos con alto impacto, **Auco** establece planes específicos de respuesta, incluyendo:

- **Phishing dirigido:** Bloqueo inmediato del remitente, alerta interna y capacitación correctiva.
- **Falla de infraestructura:** Activación de servidores de respaldo y notificación a clientes sobre tiempos de recuperación.
- **Acceso no autorizado:** Revocación de credenciales comprometidas y análisis forense para identificar la causa.
- **Fuga de datos:** Informe interno, refuerzo de controles de seguridad y reporte a autoridades si es necesario.

5.5 Monitoreo y Mejora Continua

La gestión de riesgos en **Auco** es un proceso dinámico, basado en el ciclo de mejora continua (PDCA - Plan, Do, Check, Act):

Planificar: Identificar riesgos y definir estrategias de mitigación.

Ejecutar: Implementar controles de seguridad y medidas preventivas.

Verificar: Auditar periódicamente para detectar fallos o áreas de mejora.

Actuar: Ajustar las estrategias según nuevas amenazas o cambios en la organización.

Ejemplo: Si una auditoría revela un alto número de intentos de acceso fallidos, se refuerza la política de contraseñas y se implementan restricciones adicionales.

6. Cumplimiento y Actualización

El cumplimiento y la actualización de la **Política de Seguridad de la Información** son esenciales para garantizar la protección de los datos y activos de **Auco**, alineándose con regulaciones, estándares y mejores prácticas del sector.

Este apartado define los mecanismos para asegurar que la política se cumpla dentro de la organización y se actualice periódicamente para enfrentar nuevas amenazas y cambios normativos.

6.1 Cumplimiento de la Política de Seguridad

Para garantizar que la política se implemente de manera efectiva, **Auco** establece los siguientes mecanismos de cumplimiento:

6.1.1 Responsabilidades del Cumplimiento

- **Equipo de Seguridad de la Información:** Supervisa la aplicación de la política y realiza auditorías internas.
- **Departamentos de Tecnología y Operaciones:** Implementan controles técnicos y operativos.
- **Gerencia y Directivos:** Garantizan el alineamiento estratégico y la asignación de recursos.
- **Todos los empleados:** Cumplen con las normas de seguridad y reportan incidentes o incumplimientos detectados.

Ejemplo: Un colaborador que detecte un acceso no autorizado debe reportarlo inmediatamente al equipo de seguridad.

6.1.2 Auditorías y Evaluaciones de Cumplimiento

Para verificar que se cumplan las disposiciones de la política, **Auco** realiza:

Auditorías internas: Evaluaciones semestrales del cumplimiento de la política.

Pruebas de seguridad (Pentesting): Simulación de ataques para detectar vulnerabilidades.

Monitoreo continuo: Supervisión de accesos, incidentes y anomalías en los sistemas.

Evaluaciones de terceros: Revisión por parte de auditores externos para garantizar cumplimiento normativo.

Ejemplo: Si una auditoría revela que algunos empleados usan contraseñas débiles, se refuerza la política de contraseñas y se implementa autenticación multifactor.

6.1.3 Consecuencias del Incumplimiento

Cualquier incumplimiento de la política de seguridad puede derivar en:

Advertencias y sanciones: Dependiendo de la gravedad de la falta.

Revocación de accesos: Si se detecta un uso indebido de los sistemas.

Acciones legales: En casos de negligencia grave o daño intencional.

Ejemplo: Un empleado que comparta credenciales de acceso con terceros puede enfrentar sanciones disciplinarias.

6.2 Actualización de la Política de Seguridad

Dado que las amenazas cibernéticas y regulaciones evolucionan constantemente, **Auco** establece un proceso de actualización periódica de su política de seguridad.

6.2.1 Frecuencia de Actualización

La política se revisará al menos **una vez al año** y se actualizará en los siguientes casos:

Cambios en normativas de seguridad o protección de datos.

Implementación de nuevas tecnologías o procesos en la organización.

Identificación de nuevas amenazas o vulnerabilidades.

Recomendaciones derivadas de auditorías internas o externas.

Ejemplo: Si se aprueba una nueva ley de protección de datos en Colombia, la política se ajustará para cumplir con la regulación.

6.2.2 Proceso de Actualización

Las actualizaciones seguirán estos pasos:

1. **Evaluación de Necesidad:** Identificación de cambios normativos o técnicos que requieran modificaciones.

2. **Propuesta de Cambios:** Elaboración de un borrador con los ajustes necesarios.

3. **Revisión y Aprobación:** Evaluación por parte del Comité de Seguridad de la Información.

4. **Comunicación y Capacitación:** Difusión de los cambios a los colaboradores y capacitación sobre las nuevas disposiciones.

5.**Implementación y Seguimiento:** Aplicación de los cambios y monitoreo del cumplimiento.

Ejemplo: Si se detecta una nueva técnica de phishing dirigida a la empresa, la política se actualiza para incluir medidas de prevención y respuesta.

6.2.3 Comunicación de Actualizaciones

Cada vez que la política sea modificada, se notificará a los empleados mediante:

Correos electrónicos oficiales.

Capacitaciones y sesiones informativas.

Publicación en la intranet corporativa.

Ejemplo: Si se introduce un nuevo protocolo de seguridad, se capacita a todos los empleados sobre su aplicación.

6.3 Integración con Normativas y Estándares

La política de seguridad de **Auco** se basa en estándares internacionales y regulaciones nacionales, como:

ISO 27001: Norma internacional de seguridad de la información.

Ley 1581 de 2012 (Colombia): Protección de datos personales.

NIST Cybersecurity Framework: Mejores prácticas para la gestión de riesgos de ciberseguridad.

Ejemplo: Si un cliente firma digitalmente un contrato con datos sensibles, **Auco** garantiza cifrado, autenticación robusta y trazabilidad, cumpliendo con estas normativas.

6.4. Mejora Continua

La seguridad de la información es un proceso dinámico. **Auco** adopta un enfoque de mejora continua para:

Fortalecer los controles de seguridad.

Actualizar procesos ante nuevas amenazas.

Capacitar continuamente al personal.

Ejemplo: Si un ataque reciente afecta a empresas del sector, **Auco** analiza el incidente y ajusta su política para prevenir riesgos similares.